

NexusFinance —

សន្តិសុខនិងការអនុវត្ត

ប្រព័ន្ធគ្រប់គ្រងប្រាក់កម្ចីឌីជីថលសម្រាប់កម្ពុជា

KH

Document Number	NF-DOC-003
Version	1.0
Date	សីហា 2026
Prepared By	NDX Digital Support
Classification	Internal & Confidential

មាតិកា

1. ស្ថាបត្យកម្មការផ្ទៀងផ្ទាត់
2. សន្តិសុខពាក្យសម្ងាត់
3. ប្រព័ន្ធផ្ទៀងផ្ទាត់ OTP
4. ការគ្រប់គ្រងសម័យនិង Token
5. ការគ្រប់គ្រងតួនាទី
6. Audit Logging
7. សន្តិសុខ API
8. ការពារទិន្នន័យ
9. សន្តិសុខការទូទាត់

១. ស្ថាបត្យកម្មការផ្ញើផ្ទាំងផ្ទាត់

NexusFinance ប្រើប្រព័ន្ធផ្ញើផ្ទាំងផ្ទាត់ពហុស្រទាប់ដែលរួមបញ្ចូល អ៊ីមែល/ពាក្យសម្ងាត់ជាមួយ OTP។
លំហូរទាំងអស់ដំណើរការដោយ Express backend។

២. សន្តិសុខពាក្យសម្ងាត់

- ពាក្យសម្ងាត់ hash ដោយ bcrypt ជាមួយ salt rounds = 10
- ពាក្យសម្ងាត់អត្ថបទមិនរក្សាទុក
- ការប្រៀបធៀបប្រើ bcrypt.compare()
- រយៈពេលអប្បបរមា: ៦ តួអក្សរ

៣. ប្រព័ន្ធផ្ញើផ្ទាំងផ្ទាត់ OTP

លក្ខណៈ	តម្លៃ
ប្រវែងកូដ	៦ ខ្ទង់
វិធីសាស្ត្រ Hash	bcrypt (10 rounds)
ការផុតកំណត់	១០ នាទី
ការផ្ញើផ្ទាំងផ្ទាត់	Brevo transactional email

៤. ការគ្រប់គ្រងសម័យនិង Token

- JWT tokens ចេញនៅពេលចូលជោគជ័យ
- មាតិកា token: id, email, name, role
- Tokens រក្សាទុកក្នុង browser localStorage

៥. ការគ្រប់គ្រងតួនាទី

តួនាទី	សិទ្ធិ
customer	សុំកម្ចី មើលប្រតិបត្តិការ គ្រប់គ្រងប្រែប្រួល
loan-officer	ពិនិត្យសំណុំបែបបទ អនុម័ត/បដិសេធ មើល stats និង tasks
super-admin	សិទ្ធិពេញលេញ: វិភាគ គ្រប់គ្រងអ្នកប្រើប្រាស់ config audit log

រាល់ API endpoints អនុវត្តការត្រួតពិនិត្យតួនាទីខាងលើ។ ការអនុម័ត/បដិសេធ/កម្ចី កម្ចី និង endpoint stats និង tasks តម្រូវឱ្យមានតួនាទី loan-officer ឬ super-admin។

៦. Audit Logging

- រាល់សកម្មភាពសំខាន់ៗទាំងអស់ត្រូវបានកត់ត្រា
- Audit logs append-only និងមើលឃើញដោយអ្នកគ្រប់គ្រង

៧. សន្តិសុខ API

- Rate limiting នៅលើ endpoint ផ្សេងៗគ្នា
- CORS កំណត់ត្រឹមត្រូវ
- HTTPS តម្រូវសម្រាប់ endpoint ទាំងអស់

៨. ការពារទិន្នន័យ

- ទិន្នន័យអ្នកប្រើប្រាស់រក្សាទុកក្នុង Supabase
- Service role key សម្រាប់ server-side operations
- គ្មានព័ត៌មានផ្ទាល់ខ្លួនក្នុង logs

៩. សន្តិសុខការទូទាត់

- កូដ KHQR បង្កើតខាងសេរី
- ការផ្ទៀងផ្ទាត់តម្រូវឱ្យមាន API call
- សំណើ ABA PayWay purchase ចុះហត្ថលេខាជាមួយ HMAC-SHA512 (24-field fixed hash order)
- Webhook callback ផ្ទៀងផ្ទាត់ជាមួយ HMAC signature ដូចគ្នាមុនដំណើរការ
- Hosted checkout រក្សាទិន្នន័យប័ណ្ណលើទំព័រ PCI-compliant របស់ ABA — មិនមែនលើ server របស់យើង
- Sandbox mode សកម្ម